

UNIVERSIDADE FEDERAL DE GOIÁS
INSTITUTO DE INFORMÁTICA
BACHARELADO EM SISTEMAS DE INFORMAÇÃO

Plano de Validação, Segurança e Auditoria - eFCaaS

SQUAD 04

Versão	Data	Autor
1.0	16/06/2026	gustavo_melo2@discente.ufg.br
1.1	20/06/2026	bruno.vieira@discente.ufg.br

1 - Introdução.....	3
1.1 - Objetivo.....	3
1.2 - Escopo.....	4
1.3 - Base de Referências.....	4
2 - Estratégia de validação.....	5
2.1 - Critério Gerais.....	5
2.2 - Plano de Testes.....	5
2.2.1 - Testes Unitários.....	5
2.2.2 - Testes de Integração.....	8
2.2.3 - Testes End-to-End.....	9
3 - Validação de Segurança.....	12
3.1 - Modelo de Controle de Acesso.....	12
3.2 - Matriz de Permissões Padrão.....	12
3.3 Casos de Teste de Segurança.....	13
4 - Plano de Auditoria Continuada.....	15
4.1 - Objetivo.....	15
4.2 - Eventos Auditáveis.....	15
4.3 - Informações Registradas.....	16
5 - Parecer Final.....	17

1 - Introdução

Este documento estabelece o Plano de Validação, Segurança e Auditoria do sistema eFCaaS. Seu propósito é definir as diretrizes e os procedimentos técnicos necessários para homologar a aplicação, garantindo que ela opere de acordo com os padrões de qualidade e proteção exigidos pelo projeto.

1.1 - Objetivo

Este documento tem como objetivo definir os procedimentos de validação da plataforma eFCaaS, contemplando:

- **Plano de testes:** estruturação das abordagens de testes (unitários, de integração e ponta a ponta), definindo cenários, critérios de aceite e ferramentas a serem utilizadas.
- **Validação dos requisitos funcionais:** confirmação de que todas as funcionalidades, fluxos e regras de negócio operam exatamente conforme especificado nos requisitos do produto (PRD).
- **Validação dos requisitos não funcionais:** aferição prática das métricas de desempenho, escalabilidade, latência e disponibilidade estipuladas para a arquitetura do sistema.
- **Verificação dos mecanismos de segurança:** testes das camadas de proteção, incluindo a validação da criptografia de dados (em repouso e trânsito) e a prevenção contra vulnerabilidades conhecidas.
- **Avaliação dos controles de acesso:** revisão técnica dos fluxos de autenticação e garantia de que o modelo de permissões (RBAC) e o isolamento entre tenants funcionam corretamente.
- **Estratégia de auditoria contínua:** definição das políticas de geração, monitoramento e retenção de logs estruturados, assegurando a rastreabilidade histórica de eventos críticos.
- **Evidências de conformidade:** geração e organização de artefatos (relatórios, registros e documentações) que comprovem o alinhamento do sistema à LGPD e a explicabilidade das análises da IA.

1.2 - Escopo

O escopo das atividades de validação, segurança e auditoria abrangerá todos os fluxos críticos e componentes arquiteturais da plataforma eFCaaS. Os testes e verificações incidirão sobre os seguintes módulos:

- **Gestão de Identidade e Acesso:** Validação dos mecanismos de autenticação, controle de sessões, isolamento entre organizações (multi-tenant) e aplicação rigorosa do controle de acesso baseado em perfis (RBAC - Gestor, Checador, Curador e Editor).
- **Fluxo de Curadoria e Checagem:** Homologação da entrada de dados, triagem de mídias, registro de evidências e transição de status das análises. Inclui a validação do processamento da Inteligência Artificial, garantindo a performance esperada e a explicabilidade de seus resultados.
- **Revisão Editorial e Publicação:** Testes nos fluxos de aprovação de conteúdo, versionamento de textos e consistência dos dados gerados no acervo final.
- **Administração e Parametrização:** Verificação das configurações de sistema, gestão de usuários e integridade das parametrizações globais da plataforma.
- **Auditoria e Rastreabilidade:** Comprovação da geração, estruturação e armazenamento seguro dos logs do sistema, garantindo a retenção adequada e o rastreamento imutável de todas as ações críticas e mutações na base de dados.

1.3 - Base de Referências

PRD - eFCaaS
Épicos de Usuário - Checador
Épicos de Usuário - Curador
Épicos de Usuário - Administrador
Diagrama de Entidades e Relacionamentos

2 - Estratégia de validação

A estratégia de validação do eFCaaS baseia-se na execução sistemática de testes funcionais, não funcionais, de segurança e de auditoria. O objetivo dessa abordagem é garantir que todos os componentes da arquitetura e fluxos de negócio operem de acordo com as especificações do produto (PRD) e os Requisitos Não Funcionais (RNFs), mitigando riscos antes da liberação do sistema para o ambiente de produção.

2.1 - Critério Gerais

A validação será considerada satisfatória e o sistema habilitado para implantação em produção sob os seguintes marcos formais:

- **100% dos Critérios de Aceite Adotados:** Verificação prática e visual de todas as telas operantes.
- Bloqueio completo de qualquer cenário que gere falhas imprevistas ou quebras de integridade.
- **Aderência ao Modelo de Controle de Clientes (RBAC):** Restrição de navegação e botões em tela garantida por checagem granular baseada em ID de perfil.
- **Registro de Auditoria Consistente:** Confirmação de escrita automática de registros de log em qualquer operação mutacional efetuada pelos usuários.

2.2 - Plano de Testes

2.2.1 - Testes Unitários

ID	Módulo	Caso de Teste	Resultado Esperado
TU-01	Autenticação	Validar formato de e-mail	E-mails inválidos devem ser rejeitados
TU-02	Autenticação	Validar política de senha	Senhas fora dos requisitos devem ser rejeitadas
TU-03	Usuários	Atualização de perfil	Dados válidos devem ser persistidos
TU-04	Usuários	Upload de foto de perfil	Apenas formatos de arquivo

			válidos devem ser permitidos
TU-05	Usuários	Troca de e-mail	Solicitação deve gerar token de confirmação
TU-06	Usuários	Alteração de senha	Nova senha deve invalidar sessões anteriores
TU-07	RBAC	Verificação de permissão	Usuário deve acessar apenas recursos autorizados
TU-08	RBAC	Carregamento de perfil	Permissões devem ser carregadas conforme perfil atribuído
TU-09	RBAC	Revogação de permissão	Permissão removida não deve mais conceder acesso
TU-10	Dashboard	Cálculo de contagem por status	Quantidades devem refletir corretamente os registros existentes
TU-11	Dashboard	Distribuição percentual de etiquetas	Percentuais devem somar 100%
TU-12	Dashboard	Histórico de atividades	Eventos devem ser agrupados corretamente por período
TU-13	Curadoria	Classificação de origem da denúncia	Canal informado deve ser categorizado corretamente
TU-14	Curadoria	Validação de briefing	Briefing deve aceitar texto livre e respeitar limites definidos
TU-15	Curadoria	Atribuição de tarefa	Tarefa deve ser vinculada ao chegador selecionado
TU-16	Curadoria	Atualização de status do Kanban	Mudança de coluna deve atualizar o status correspondente
TU-17	Curadoria	Filtro por risco	Apenas itens compatíveis devem ser retornados
TU-18	Curadoria	Cálculo de risco da denúncia	Resultado deve respeitar a escala definida pelo sistema
TU-19	Curadoria	Classificação automática de tema	Categoria retornada deve pertencer à lista válida
TU-20	Checagem	Cadastro de link de evidência	URL válida deve ser aceita
TU-21	Checagem	Cadastro de imagem/ vídeo de evidência	Arquivo compatível deve ser registrado corretamente
TU-22	Checagem	Exclusão de evidência	Evidência removida não deve

			permanecer visível
TU-23	Checagem	Validação do resumo da checagem	Campos obrigatórios devem ser validados
TU-24	Checagem	Quantidade máxima de perguntas	Sistema deve limitar conforme configuração administrativa
TU-25	Checagem	Registro de fontes	Fontes válidas devem ser associadas ao relatório
TU-26	Checagem	Marcação de conteúdo inverificável	Indicador deve ser persistido corretamente
TU-27	Checagem	Seleção de etiqueta	Pelo menos uma etiqueta deve ser obrigatória
TU-28	Checagem	Recuperação de etiquetas oficiais	Apenas etiquetas ativas devem ser exibidas
TU-29	Editorial	Montagem de prompt interno	Dados do parecer/relatório devem ser incorporados ao prompt
TU-30	Editorial	Geração de rascunho	Estrutura montada deve conter resumo, fontes e perguntas
TU-31	Administração	Criação de Usuário	Registro deve ser criado com perfil válido
TU-32	Administração	Suspensão de Usuário	Usuário deve ser marcado como bloqueado
TU-33	Administração	Convite de primeiro acesso	Token de ativação deve ser gerado
TU-34	Administração	Cadastro de perfil personalizado	Perfil deve armazenar permissões selecionadas
TU-35	Administração	Criação de etiqueta	Não permitir nomes duplicados
TU-36	Administração	Exclusão de etiqueta	Etiqueta deve ser removida corretamente
TU-37	Administração	Configuração de campos obrigatórios	Regra deve ser aplicada na validação dos relatórios
TU-38	Administração	Configuração de limite de perguntas	Valor deve ser respeitado pelos formulários
TU-39	Administração	Alteração de tema	Configurações visuais devem ser persistidas
TU-40	Auditoria	Registro de evento	Evento deve gerar entrada de log

TU-41	Auditoria	Formatação de log	Log deve conter usuário, ação e timestamp
-------	-----------	-------------------	---

2.2.2 - Testes de Integração

ID	Módulos Integrados	Caso de Teste	Resultado Esperado
TI-01	Autenticação ↔ Usuários	Login com credenciais válidas	Usuário autenticado e perfil carregado corretamente
TI-02	Autenticação ↔ RBAC	Login de usuário com perfil específico	Permissões devem ser carregadas conforme o perfil
TI-03	Usuários ↔ Auditoria	Alteração de perfil	Evento deve ser registrado nos logs
TI-04	Usuários ↔ Notificações	Alteração de e-mail	E-mail de confirmação deve ser enviado
TI-05	Administração ↔ Usuários	Criação de usuário	Usuário deve ser criado e receber convite de acesso
TI-06	Administração ↔ RBAC	Associação de perfil a usuário	Permissões do perfil devem ser aplicadas imediatamente
TI-07	Administração ↔ Auditoria	Alteração de permissões	Alteração deve ser registrada em log
TI-08	Administração ↔ Checagem	Criação de etiqueta	Etiqueta deve ficar disponível para utilização nos relatórios
TI-09	Curadoria, Checagem, Editorial ↔ Dashboard	Movimentação de tarefas	Indicadores do dashboard devem ser atualizados
TI-10	Checagem ↔ Curadoria	Mudança de etapa na tarefa	Status da tarefa deve ser refletido no kanban
TI-11	Curadoria ↔ Checagem	Atribuição de tarefa	Tarefa deve aparecer na fila do chegador
TI-12	Curadoria ↔ Notificações	Atribuição de tarefa	Chegador deve ser notificado da nova

			tarefa
TI-13	Curadoria, Checagem, Editorial ↔ Auditoria	Mudança de status de tarefa/publicação	Status da tarefa/publicação deve ser registrada no log
TI-14	Curadoria ↔ IA dEnodare	Solicitação de análise de IA	Dados do caso devem ser enviados ao serviço de IA
TI-15	Curadoria ↔ IA dEnodare	Busca e extração de conteúdo de redes sociais	Parâmetros de busca em redes sociais devem ser enviados ao serviço de IA
TI-16	Checagem, Editorial ↔ IA Geração de texto	Geração de rascunho de parecer/publicação	Conteúdo deve ser enviado ao serviço de IA
TI-17	Checagem ↔ Editorial	Parecer de checagem finalizado	Parecer de checagem aparece na fila do editor para elaboração de publicação

2.2.3 - Testes End-to-End

E2E-01 – Fluxo Completo de Checagem de Fato	
Objetivo	Validar o ciclo completo de verificação de uma denúncia, desde sua entrada até a publicação do conteúdo.
Pré-condições	• Curador autenticado. • Checador ativo. • Etiquetas configuradas. • Integração de IA habilitada.
Passos	1. Curador registra um novo conteúdo. 2. Curador envia conteúdo para análise da IA. 3. Curador adiciona briefing e contexto. 4. Curador atribui a tarefa a um checador. 5. Checador recebe a atribuição. 6. Checador adiciona evidências e fontes. 7. Sistema gera rascunho do parecer.

	8. Checador revisa e finaliza o relatório. 9. Curador realiza a revisão final. 10. Relatório é aprovado. 11. Relatório é enviado para módulo editorial.
Resultado Esperado	• Denúncia processada com sucesso. • Relatório final disponível para publicação. • Todas as ações registradas na auditoria.

E2E-02 – Fluxo de Primeiro Acesso de Usuário	
Objetivo	Validar o processo completo de criação e ativação de usuários.
Pré-condições	• Administrador autenticado.
Passos	1. Administrador cria um novo usuário. 2. Sistema envia convite por e-mail. 3. Usuário acessa o link recebido. 4. Usuário define senha. 5. Usuário realiza login. 6. Sistema carrega permissões associadas ao perfil.
Resultado Esperado	• Usuário criado e ativado. • Perfil RBAC aplicado corretamente. • Registro de auditoria gerado.

E2E-03 – Fluxo de Administração de Perfis e Permissões	
Objetivo	Validar a gestão completa de permissões.
Passos	1. Administrador cria um perfil personalizado. 2. Define permissões específicas.

	3. Associa o perfil a um usuário. 4. Usuário realiza login. 5. Usuário tenta acessar funcionalidades permitidas. 6. Usuário tenta acessar funcionalidades não autorizadas.
Resultado Esperado	• Permissões aplicadas corretamente. • Acessos indevidos bloqueados. • Eventos registrados na auditoria.

E2E-04 – Fluxo de Criação de Etiquetas	
Objetivo	Validar a criação e utilização de etiquetas de classificação.
Passos	1. Administrador cria nova etiqueta. 2. Etiqueta é disponibilizada no sistema. 3. Checador elabora um relatório. 4. Etiqueta é selecionada. 5. Relatório é salvo. 6. Dashboard atualiza estatísticas associadas.
Resultado Esperado	• Etiqueta vinculada ao relatório. • Indicadores atualizados corretamente

E2E-02 – Fluxo de Edição de Relatórios para Publicação	
Objetivo	Validar o processo de edição dos pareceres de checagem para publicação

Passos	1. Checador marca tarefa de checagem como concluída. 2. Curador revisa o parecer de checagem. 3. Curador aprova parecer de checagem. 4. Parecer é enviado para fila do editor 5. Editor seleciona parecer 6. Editor trabalha para transformar o parecer em publicação
Resultado Esperado	• Publicação gerada a partir do parecer de checagem • Publicação registrada no acervo editorial

3 - Validação de Segurança

3.1 - Modelo de Controle de Acesso

Com o objetivo de garantir a segurança das informações e assegurar que cada usuário possua apenas os acessos necessários para o desempenho de suas funções, a plataforma adotará o modelo de Controle de Acesso Baseado em Papéis (Role-Based Access Control – RBAC).

Nesse modelo, as permissões são associadas a perfis de usuário previamente definidos, permitindo uma administração centralizada dos privilégios e reduzindo os riscos decorrentes de acessos indevidos.

Foram estabelecidos quatro perfis principais de acesso principais com suas permissões já definidas por padrão e também a possibilidade de criação de perfis personalizados.

3.2 - Matriz de Permissões Padrão

Funcionalidade	Administrador	Checador	Curador	Editor	Perfil Personalizado*
Realizar login	✓	✓	✓	✓	✓
Gerenciar perfil próprio	✓	✓	✓	✓	Configurável
Consultar conteúdos	✓	✓	✓	✓	Configurável

Criar análises e verificações	✓	✓	X	X	Configurável
Editar análises próprias	✓	✓	X	X	Configurável
Revisar análises	✓	X	✓	X	Configurável
Aprovar ou reprovar conteúdos	✓	X	✓	X	Configurável
Encaminhar conteúdo para publicação	✓	X	✓	X	Configurável
Editar conteúdos publicados	✓	X	X	✓	Configurável
Publicar conteúdos	✓	X	X	✓	Configurável
Despublicar conteúdos	✓	X	X	✓	Configurável
Gerenciar usuários	✓	X	X	X	Configurável
Criar e alterar perfis de acesso	✓	X	X	X	Configurável
Configurar parâmetros do sistema	✓	X	X	X	X
Consultar logs de auditoria	✓	X	✓	X	Configurável
Exportar relatórios	✓	✓	✓	✓	Configurável
Gerenciar conteúdos em todas as etapas do fluxo	✓	X	X	X	Configurável

3.3 Casos de Teste de Segurança

CTS-01 – Tentativa de Acesso sem Autenticação	
Objetivo	Verificar se usuários não autenticados não conseguem acessar recursos protegidos.
Procedimento	1. Encerrar a sessão do sistema. 2. Tentar acessar diretamente uma URL

	protegida.
Resultado Esperado	• Redirecionamento para a tela de login. • Nenhum dado protegido é exibido.

CTS-02 – Controle de Acesso por Perfil (RBAC)	
Objetivo	Validar que usuários acessam apenas funcionalidades autorizadas.
Procedimento	1. Autenticar como Checador. 2. Tentar acessar funcionalidades exclusivas do Administrador.
Resultado Esperado	• Acesso negado. • Operação registrada na auditoria.

CTS-03 – Força Bruta de Login	
Objetivo	Validar mecanismos de proteção contra tentativas repetidas de autenticação.
Procedimento	1. Realizar múltiplas tentativas consecutivas com senha incorreta
Resultado Esperado	• Conta temporariamente bloqueada ou protegida por mecanismo de mitigação. • Tentativas registradas em log.

CTS-04 – Expiração de Sessão	
Objetivo	Verificar o encerramento automático de sessões inativas.
Procedimento	1. Realizar login. 2. Permanecer inativo pelo período configurado.

Resultado Esperado	- Sessão encerrada automaticamente. - Novo login exigido.
---------------------------	--

CTS-05 – Validação de Upload de Arquivos	
Objetivo	Verificar restrições de upload de evidências/conteúdo
Procedimento	- Enviar arquivo permitido. - Enviar arquivo executável ou formato não autorizado.
Resultado Esperado	- Arquivos válidos aceitos. - Arquivos proibidos são rejeitados.

4 - Plano de Auditoria Continuada

4.1 - Objetivo

Estabelecer procedimentos contínuos de monitoramento e auditoria da plataforma **eFCaaS**, garantindo a integridade dos dados, a conformidade dos processos operacionais, a segurança das informações e a rastreabilidade das ações executadas pelos usuários.

A auditoria continuada tem como finalidade identificar desvios operacionais, acessos indevidos, falhas de conformidade e possíveis vulnerabilidades, permitindo a adoção de ações corretivas e preventivas.

4.2 - Eventos Auditáveis

Categoria	Evento
Autenticação	Login realizado
Autenticação	Logout realizado
Autenticação	Falha de login
Autenticação	Redefinição de senha
Usuários	Criação de usuário

Usuários	Alteração de perfil
Usuários	Bloqueio ou suspensão
RBAC	Alteração de permissões
RBAC	Criação ou remoção de perfis
Curadoria	Cadastro de conteúdo suspeito
Curadoria	Atribuição de tarefa
Checagem	Inclusão de evidências
Checagem	Criação de parecer
Edição	Edição do parecer pronto
Administração	Alteração de parâmetros do sistema

4.3 - Informações Registradas

Para garantir a integridade, a rastreabilidade e a conformidade legal das operações, cada evento auditado deverá gerar um registro estruturado de log contendo, no mínimo, as seguintes informações obrigatórias:

- **Identificador único (ID):** Código de rastreio exclusivo para localização e correlação do evento.
- **Data e horário (Timestamp):** Registro temporal exato da ocorrência da ação.
- **Identificação do ator:** Credenciais do usuário responsável pela execução e o seu respectivo perfil de acesso (RBAC) ativo no momento da operação.
- **Origem da requisição:** Endereço IP da máquina originadora e, quando aplicável, dados do agente do usuário (*User-Agent*).
- **Contexto da operação:** Módulo do sistema, serviço e recurso específico afetado pela ação.
- **Ação executada:** Natureza da operação realizada (ex.: criação, leitura, atualização, exclusão ou tentativa de acesso).
- **Status de conclusão:** Resultado final do evento processado (sucesso, falha ou bloqueio de segurança).
- **Detalhes da mutação (Payload):** Dados relevantes da alteração, contemplando, sempre que possível, o estado anterior e o novo estado da informação modificada.

5 - Parecer Final

A homologação do sistema eFCaaS será formalizada e a aplicação considerada apta para liberação (estado de *Go-Live*) somente após a constatação de que a plataforma atingiu os níveis de qualidade e segurança exigidos. O parecer final favorável estará condicionado à validação de que:

- A totalidade dos critérios de aceite definidos para os fluxos operacionais e requisitos não funcionais foi testada e aprovada com sucesso.
- Não existem defeitos, vulnerabilidades ou impedimentos de severidade crítica ou alta registrados em aberto no ciclo de desenvolvimento.
- As políticas de segurança corporativa foram comprovadas na prática, com destaque para a efetividade do controle de acesso baseado em funções (RBAC) e o isolamento de dados.
- A infraestrutura de auditoria contínua está operando corretamente, gerando, estruturando e armazenando os registros de forma confiável.